DATA PROTECTION | INSIGHT

Kenya Data Protection Act (DPA) 2019

A practical compliance roadmap: ODPC registration, lawful processing, data subject rights, DPIAs, breach notification and enforcement exposure.

Digital Asset Defenders | October 2026 | Security & Compliance Briefing

Kenya's Data Protection Act, 2019 gives effect to Article 31 of the Constitution and is enforced by the Office of the Data Protection Commissioner (ODPC). Enforcement is now routine rather than exceptional. This briefing turns the Act into a workable roadmap for controllers and processors, with the technical controls that make each obligation defensible.

Why now: by January 2026 the ODPC had received 9,061 complaints and issued 357 determinations, 134 enforcement notices, 20 penalty notices and 184 compensation orders, with 15,000+ registration certificates issued. In August 2026 it gave controllers and processors with expired certificates until 11 September 2026 to renew.

1. ODPC registration

- **Duty (s.18, Registration Regulations 2021):** a person may not act as a controller or processor unless registered, subject to the thresholds and mandatory-registration categories in the Regulations. Check whether your sector or processing purpose triggers registration regardless of size.
- **Validity:** certificates run 24 months. Apply to renew at least 30 days before expiry; processing on an expired certificate is an offence.
- **Registered particulars must stay accurate:** categories of personal data, purposes, recipients, transfers abroad and security measures. Update the ODPC when they change.
- **Retain:** certificate, application, DPO appointment, and a register of systems and vendors that supports the particulars you declared.

2. Lawful processing

Section 25 sets the principles: lawfulness, fairness and transparency; purpose limitation; minimisation; accuracy; storage limitation; security; and accountability. Every processing activity needs a documented lawful basis (s.30) before collection.

Basis	When it fits	Evidence to keep
Consent (s.32)	Marketing, optional features, cookies/analytics. Must be specific, informed, unbundled and as easy to withdraw as to give.	Consent log: who, when, wording shown, version, withdrawal.
Contract	Data needed to deliver the service the person asked for.	Contract/T&Cs mapped to data fields.
Legal obligation	KYC/AML, tax, sector regulator requirements.	Citation of the law and retention period.
Legitimate interest	Fraud prevention, network security, internal analytics. Requires a balancing test.	Written balancing assessment.
Vital interests / public task	Emergencies; public-sector functions.	Case-by-case record.

- **Sensitive personal data** (health, biometric, genetic, financial, children's data and similar categories) carries stricter conditions. Children's data (s.33) needs a lawful, age-appropriate basis and guardian consent where relevant.
- **Notice at collection (s.29):** identity of controller, purposes, recipients, transfers, retention, rights and how to complain to the ODPC.
- **Processor contracts:** written terms covering instructions, confidentiality, security, sub-processors, breach notice, deletion/return and audit.

3. Data subject rights

Right	Reference	Operational target
Be informed / access	ss.26, 29	Respond within 7 days (Regulations 2021)
Rectification and erasure	s.40	Within 14 days (Regulations 2021)
Data portability	s.38	Structured, commonly used, machine-readable format
Object to processing, incl. direct marketing	s.26	Stop marketing on objection; honour opt-outs across all channels
Not be subject to solely automated decisions	s.35	Human review path for scoring, credit or fraud decisions

- Build a single intake channel (form and mailbox), verify identity proportionately, and log every request with a closure date.
- Map each system holding personal data so erasure and access cover backups, analytics, CRM, ticketing and processors.
- Check current regulation text for exact timelines before publishing SLAs externally.

4. Data Protection Impact Assessments (s.31)

A DPIA is required where processing is likely to create a high risk to rights and freedoms. Typical triggers: large-scale sensitive data, systematic monitoring (CCTV, location, behavioural tracking), biometrics, profiling or automated decisions, new technology (AI scoring, mobile-money integrations), and large-scale data matching.

Step	Output
1. Describe the processing	Data flow diagram: sources, systems, processors, transfers, retention
2. Necessity and proportionality	Lawful basis, minimisation decisions, alternatives considered
3. Risk assessment	Likelihood x severity per risk to individuals (not to the business)
4. Mitigation	Controls with owner and date: encryption, pseudonymisation, access limits, retention
5. Sign-off and review	DPO opinion, management approval, ODPC consultation if high risk remains, re-review on change

5. Breach notification (s.43)

Clock: notify the Data Commissioner within **72 hours** of becoming aware of a breach likely to risk individuals; notify affected data subjects without unreasonable delay where there is a real risk of harm. Processors must tell the controller without delay; set a contractual limit (for example 24 to 48 hours).

- **Notification content:** nature and categories of data, approximate number of people and records, likely consequences, measures taken or proposed, DPO or contact point.
- **Decision log:** if you decide not to notify, record the reasoning. Regulators ask.
- **Pair legal and technical response:** the same incident record should hold timeline, containment, forensics and notification decisions.

Common breach path	ATT&CK	Weakness (CWE)	Detection (Windows / platform)	Remediation
Phished credentials, mailbox access	T1566, T1078.004	CWE-308 (single-factor auth)	Entra sign-in logs; 4624/4625; mailbox rule creation (T1114.003)	Phishing-resistant MFA, conditional access, disable legacy auth
SQL injection / broken access in web app	T1190	CWE-89, CWE-639 (IDOR)	WAF and DB audit logs; spikes of 4xx/5xx; bulk SELECT on PII tables	Parameterised queries, object-level authorisation, DB least privilege
Exposed storage bucket or backup	T1530	CWE-732	Cloud audit logs (public ACL changes)	Block public access by policy, encrypt, inventory data stores
Insider bulk export	T1567, T1074	CWE-285	DLP alerts; 4663 on sensitive shares; large egress	Role-based access, DLP, export approval, monitoring
Ransomware with exfiltration	T1486, T1041	CWE-1188 (insecure defaults)	4688/4698 (process, scheduled task); 1102 (log cleared); 7045 (new service)	Offline backups, EDR, segmentation, tested restore

CVSS v3.1/v4.0 scoring helps prioritise: treat internet-facing PII systems with a base score of 7.0 or higher as remediation-before-release items.

6. Cross-border transfers (ss.48-50)

- Transfers abroad need appropriate safeguards (adequacy, contractual clauses, binding corporate rules) or the data subject's informed consent for specific cases.
- Certain processing for strategic interest of the state must be done through a server or data centre located in Kenya (s.50, with supporting regulations). Confirm whether your sector is caught.
- Cloud use is a transfer analysis: record region, sub-processors and support-access locations in your vendor register.

7. Enforcement exposure

Instrument	Consequence
Enforcement notice (ss.58-62)	Order to remedy, stop processing or delete; non-compliance is an offence
Penalty notice (s.63)	Administrative fine up to KES 5 million or 1% of the previous year's turnover, whichever is lower
Compensation (s.65)	Data subjects can be awarded compensation; the ODPC has issued 184 orders so far
Offences (s.73 and specific offences)	Criminal fines and imprisonment, for example for unlawful disclosure or processing without registration
Reputation	Determinations and penalty notices are published; banks, telcos and retailers have been named

Figures and section numbers reflect the Act and public ODPC statements at the date of this briefing. Confirm against the current Act and regulations before relying on them in contracts or filings.

8. 90-day compliance roadmap

Days	Actions	Owner
0-30	Confirm registration status and renewal date; appoint DPO; build record of processing activities and vendor register; publish privacy notice	DPO / Legal
31-60	Lawful-basis review; consent and cookie fixes; data subject request workflow; processor contract addenda; DPIAs for high-risk systems	DPO / Product / Procurement
61-90	Breach runbook with 72-hour clock and tabletop test; retention schedule and deletion jobs; staff training; internal audit and board report	Security / DPO / Exec